CO-2 ASSESSMENT-2

SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration:90min Total Marks: 50

Code of Conduct:

I _____J.Vishnu Vardhan(192324297)_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.



Signature of the student:

QUESTION 1:

OSINT-Based Email Enumeration Using theHarvester

Aim

To conduct an Open-Source Intelligence (OSINT) assessment of publicly available information associated with tesla.com using theHarvester in Kali Linux, review emails and infrastructure details that are actually returned, analyze potential social-engineering risks, and recommend countermeasures.

Objectives

- Collect publicly indexed email addresses associated with the target domain, where available.
- Identify publicly discoverable subdomains, hosts, and IP addresses.
- Categorize discovered addresses by likely role only when public evidence supports the category.
- Explain how OSINT could support spear-phishing, credential harvesting, and impersonation.
- Recommend preventive, detective, and corrective controls to reduce information leakage.

Tools Required

Tool	Purpose
Kali Linux	Authorized security-testing environment.

theHarvester	Collects publicly available emails, hostnames, subdomains, and related information from supported sources.
Terminal	Execute commands and capture output.
Public data sources	Provide indexed information or certificate-transparency records, depending on source.
Text editor	Document observations and prepare the report.

Theory

OSINT is the collection and analysis of information from publicly accessible sources. theHarvester is a reconnaissance tool that queries supported sources for publicly available email addresses, hostnames, subdomains, and related infrastructure records. Results depend on source availability, indexing, rate limits, and API access. A hostname or IP address alone does not prove that a vulnerability exists.

Procedure and Commands

1. Open Kali Linux and launch the Terminal.
2. Check the installed version and available options.

   ```
   theHarvester -h
   ```
3. Run a limited hostname discovery query using a supported public source. Source names and options may differ by installed version.

   ```
   theHarvester -d tesla.com -b crtsh -l 100
   ```
4. Save the output for documentation, if the selected version supports the -f option.

   ```
   theHarvester -d tesla.com -b crtsh -l 100 -f tesla_osint
   ```

5. Review the output and record which categories were actually returned. Certificate-transparency sources are useful for hostname discovery but may not return email addresses.
6. For email enumeration, select an email-capable source supported by the installed version and check its documentation for valid source names and API-key requirements.
7. Record the date, source, exact command, number of results, and any limitations. Do not state that an item was found unless it appears in your actual output.

Findings and Role Categorization

Complete this table from your real output. The categories below are examples, not claims that these addresses or roles were discovered.

Category	**Evidence to record**	**Security significance**
Support	Verified public support contact, if found	Could be impersonated in fake support communications.
Sales	Published sales contact, if found	Could be targeted with fraudulent purchase requests.
Human Resources	Published recruitment contact, if found	Could be targeted with fake CVs or recruitment messages.
Administration	Published administrative contact, if found	Could be targeted with invoice or approval fraud.
Technical Teams	Public engineering or IT contact, if found	Could be targeted with fake technical alerts or requests.

Do not infer an employee's job title solely from an email prefix. Avoid collecting or including unnecessary private personal information.

How OSINT Can Assist an Attacker

Spear-phishing

Public contact details can make a fraudulent message appear relevant to a department. An attacker might impersonate a recruiter or IT representative and persuade an employee to open an attachment or follow a link.

Credential harvesting

A fake sign-in page may imitate a legitimate service. Employees who fail to verify the destination could disclose passwords. An awareness exercise must use a training page that never collects real passwords.

Impersonation and pretexting

Public organizational information can help someone invent a believable identity or story, such as a fake technical support request or urgent administrative approval.

Infrastructure reconnaissance

Subdomains and IP addresses may reveal publicly visible systems and technology patterns. Defenders can use these details to prioritize asset inventory and exposure reviews.

Preliminary Risk Analysis

Risk	**Likelihood**	**Impact**	**Preliminary level**
Employee-targeted phishing	High	High	High

Fake customer-support communication	Medium	High	High
Exposure of employee contact details	High	Medium	High
Misuse of public infrastructure information	Medium	High	High
Incorrectly inferring an employee role	Medium	Medium	Medium

These are qualitative scenario ratings, not measured findings about Tesla. Adjust ratings based on evidence and existing controls. Potential business impacts include account compromise, unauthorized disclosure, fraudulent payments, reputational damage, and operational disruption.

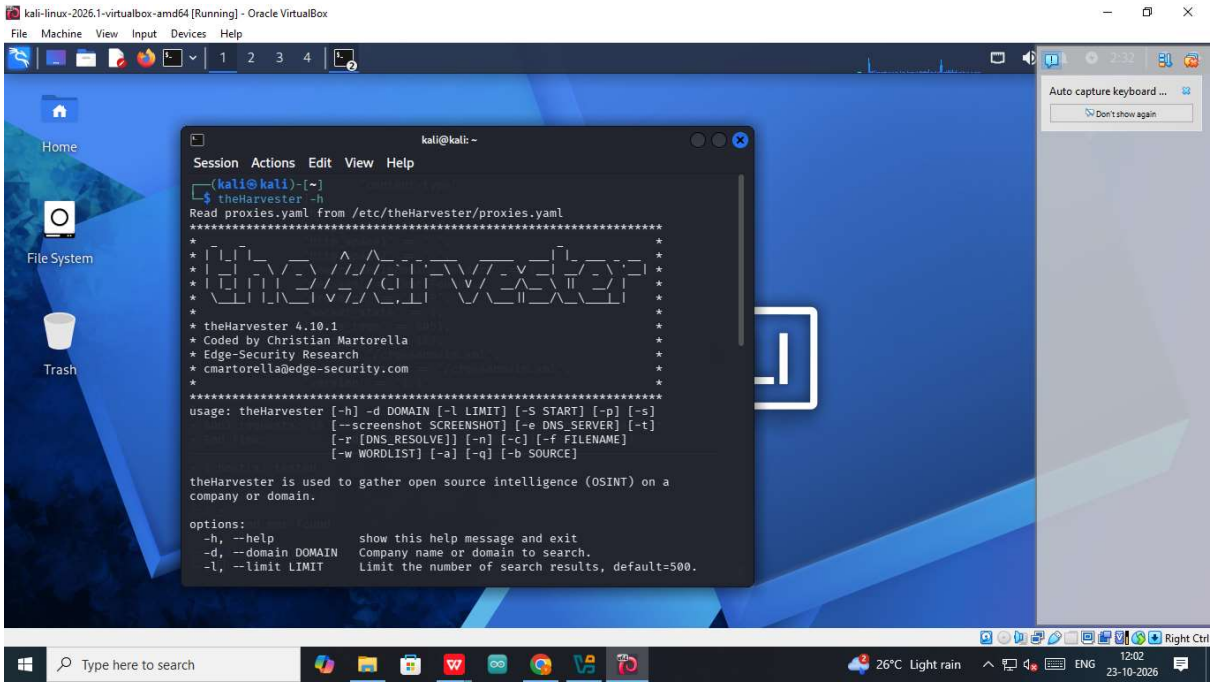
Recommended Countermeasures

8. Minimize information leakage: review public websites, job postings, documents, and metadata for unnecessary employee contacts and internal technical details.
9. Configure SPF, DKIM, and DMARC: monitor email authentication and move toward an appropriate DMARC enforcement policy after validating legitimate senders.
10. Enable multi-factor authentication: prefer phishing-resistant methods such as FIDO2 security keys or passkeys for sensitive accounts.
11. Conduct awareness training: teach employees to identify suspicious links, attachments, urgency, impersonation, and unusual payment requests.
12. Provide secure reporting: make suspicious-email reporting easy and investigate reports promptly.

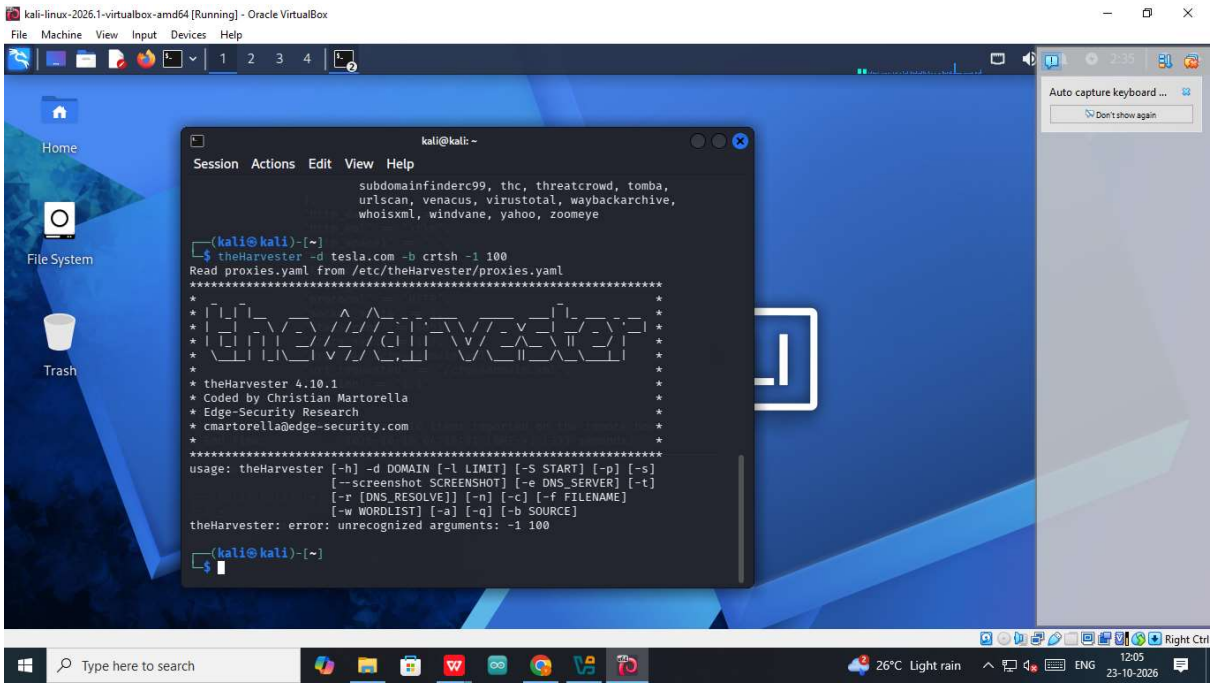
13. Review exposed infrastructure: maintain an approved inventory of domains, subdomains, hosts, and externally accessible services.
14. Apply least privilege: restrict access according to job responsibilities.
15. Monitor email and identity events: use email security controls, sign-in alerts, endpoint monitoring, and centralized logs.
16. Prepare incident response: define steps to isolate affected accounts, revoke sessions, reset compromised credentials, and investigate incidents.

Screenshots and Evidence

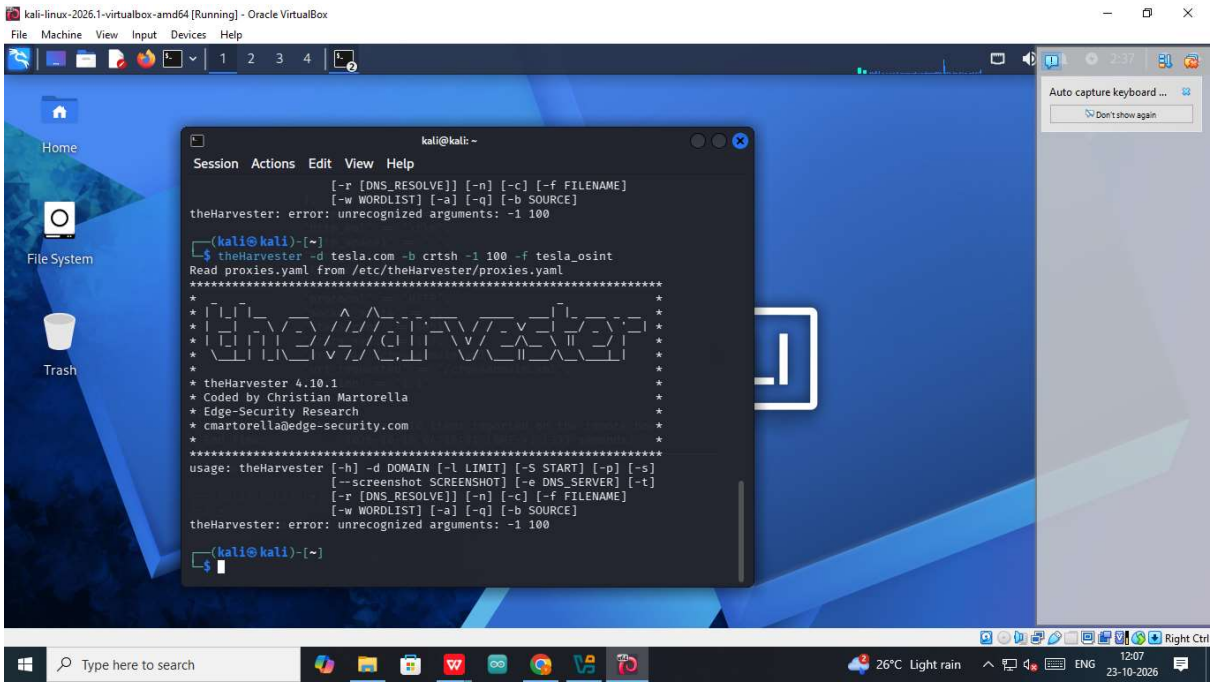
Screenshot 1: Kali terminal showing theHarvester help output.



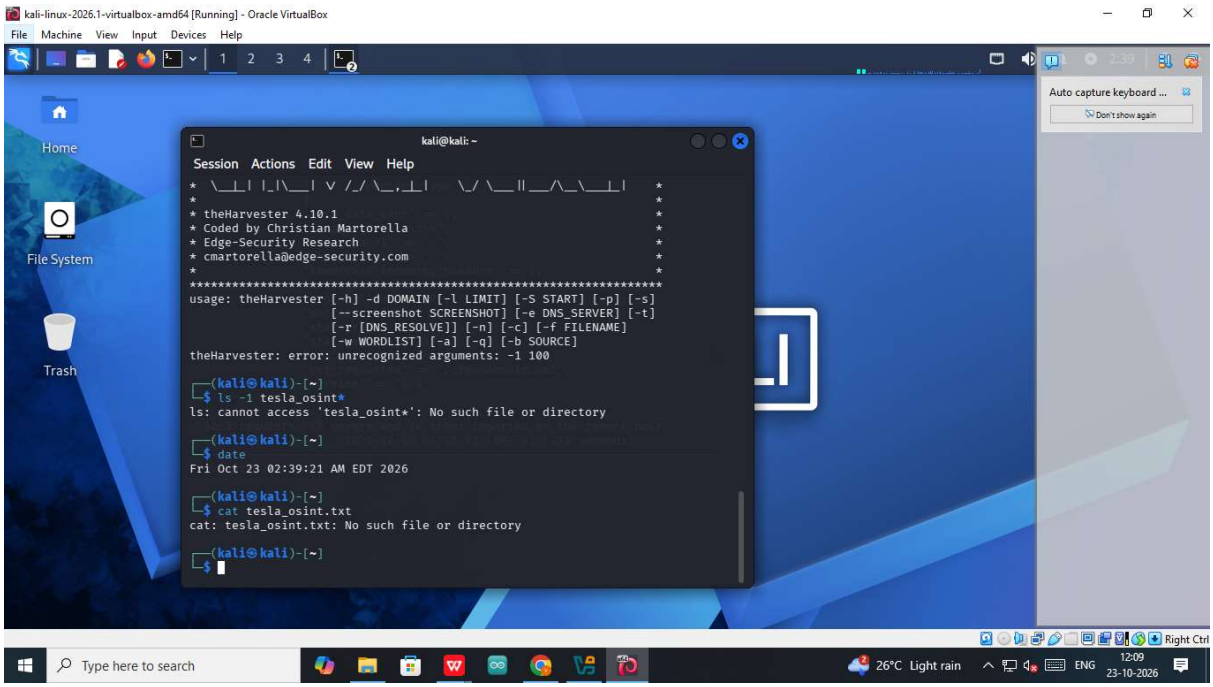
Screenshot 2: Exact command executed.



Screenshot 3: Saved output file and collection date.



Screenshot 4: Completed findings table with unnecessary sensitive details redacted.



Result

The procedure demonstrates how theHarvester can collect publicly available organizational information and how that information may be misused in social engineering. The final submission must contain actual lab results, limitations, a reasoned risk assessment, and appropriate controls.

QUESTION 2:

Phishing Awareness Simulation Using GoPhish

Aim

To conduct an authorized phishing-awareness simulation using GoPhish and dummy employee accounts, measure email delivery, opening, and link-clicking behavior, and recommend improvements to security awareness.

Objectives

- Configure GoPhish in an isolated or authorized lab environment.
- Create a realistic but harmless training email.
- Launch a campaign only against approved dummy accounts.
- Monitor delivery, opens, and clicks without collecting real credentials.
- Analyze results and recommend corrective actions.

Tools Required

Tool	Purpose
Kali Linux or approved lab computer	Simulation environment.
GoPhish	Manage email templates, recipient groups, landing pages, campaigns, and event reports.
Dummy employee accounts	Approved test recipients.
Authorized SMTP test service	Send training messages.
Web browser	View the GoPhish dashboard and training landing page.
Spreadsheet or report editor	Calculate metrics and document results.

Theory

GoPhish is an open-source platform used for authorized phishing simulations. It can manage templates, recipient groups, landing pages, campaigns, and event reporting. In a controlled exercise, the objective is to measure behavior and improve awareness, not to obtain genuine passwords or confidential information.

Procedure

17. Obtain written authorization and confirm the recipient list, campaign duration, sending limits, and scope.
18. Start GoPhish in the lab and open its administration interface using the locally configured address and port.
19. Create an approved sending profile using the lab SMTP server or test mail service and verify delivery to dummy accounts.
20. Create a recipient group containing only the supplied dummy accounts.

21. Prepare a harmless awareness email template with a controlled training link.
22. Create a landing page that explains the simulation after a click. Do not request or store actual credentials.
23. Configure and launch the campaign within the approved scope.
24. Monitor events, export results, calculate rates, and prepare the report.

Sample Email Template

Subject: Security Awareness Training – Review Required

Hello Team,

As part of our ongoing security awareness program, please review the internal security awareness notice using the training link provided by your lab instructor.

Before opening links in any email, verify the sender, inspect the destination, and report unexpected messages through the approved security reporting channel.
This is a controlled security-awareness exercise
for authorized test accounts. Regards,
Security Awareness Team

This template is intentionally harmless. A more realistic scenario should be used only if approved by the instructor and must not collect passwords, payment details, or personal information.

Campaign Metrics and Formulas

Metric	Formula	Meaning
Delivery rate	Delivered ÷ Sent × 100	Percentage of sent emails delivered.
Open rate	Unique opens ÷ Delivered × 100	Percentage of delivered emails opened.

Click rate	Unique clicks ÷ Delivered × 100	Percentage of delivered emails whose training link was clicked.

Use consistent definitions. If the dashboard uses a different denominator or event definition, state it. Open tracking is imperfect because privacy features, image blocking, and automated scanners can affect results.

Illustrative Results and Calculations

Example only — replace every figure below with your actual GoPhish results.

Metric	**Illustrative figure**	**Calculation**
Emails sent	50	Recorded from campaign.
Emails delivered	45	Recorded from campaign.
Unique opens	27	Recorded from campaign.
Unique clicks	9	Recorded from campaign.
Delivery rate	90%	45 ÷ 50 × 100
Open rate	60%	27 ÷ 45 × 100
Click rate	20%	9 ÷ 45 × 100
Not delivered	5	50 − 45

Analysis of Results

Delivery rate (illustrative 90%)

Five messages were not delivered. Investigate SMTP logs, recipient addresses, and bounce information.

Open rate (illustrative 60%)

The campaign generated measurable engagement, but opens alone do not prove a person read the message.

Click rate (illustrative 20%)

Nine recipients clicked the training link. This suggests an opportunity to improve link verification and reporting behavior.

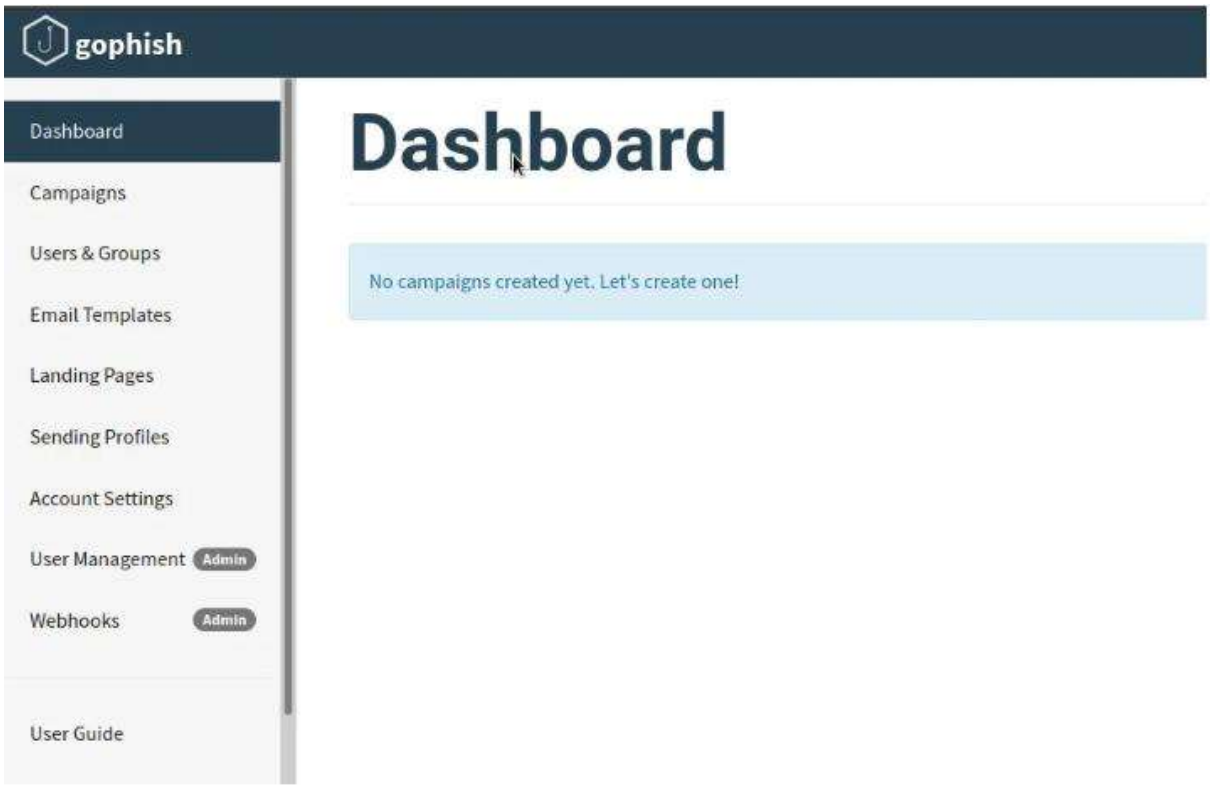
A click alone does not prove that a person would disclose credentials or that a real attack would succeed. Interpret the data in context.

Recommendations to Improve Awareness

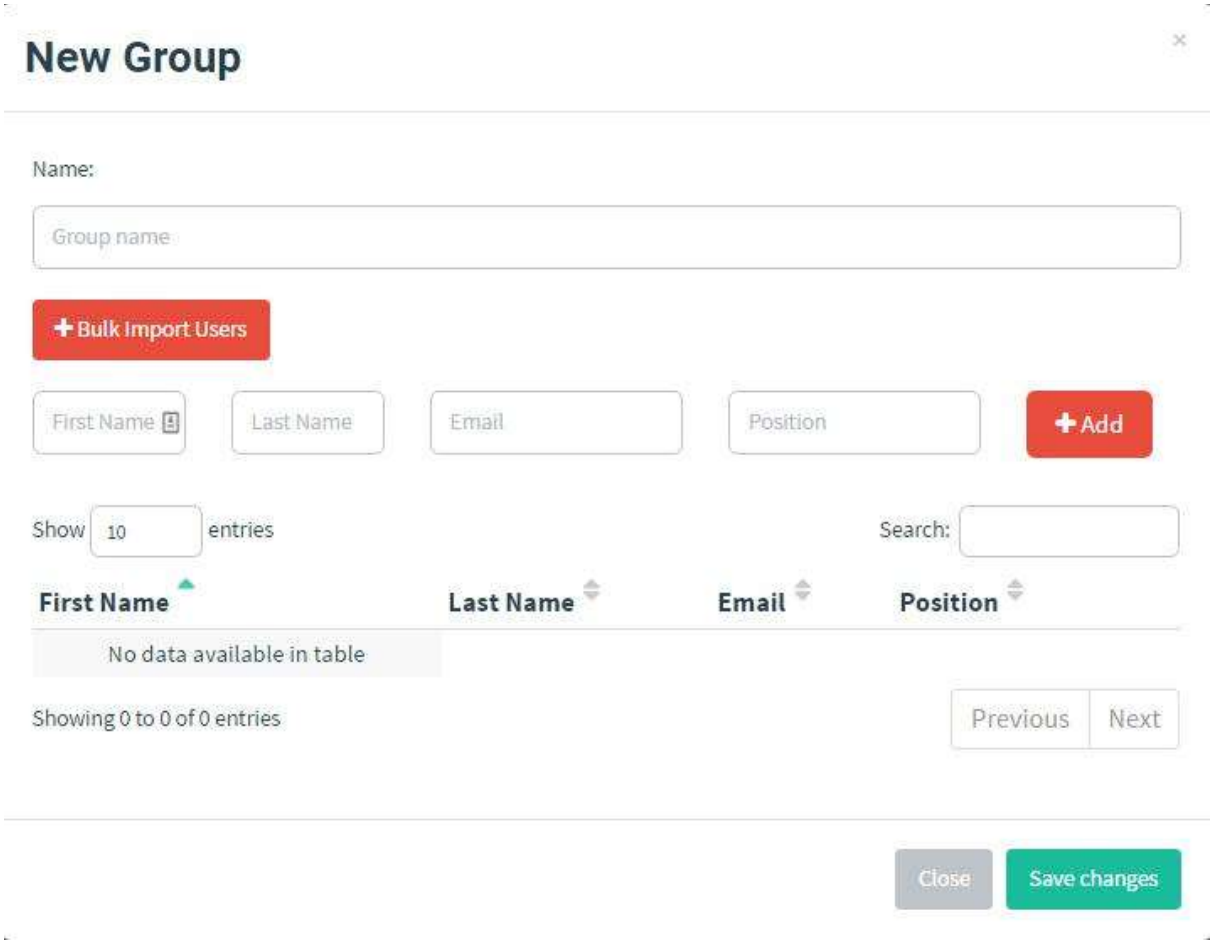
25. Conduct short, regular phishing-awareness sessions.
26. Teach employees to inspect sender addresses and link destinations.
27. Encourage verification of urgent requests through a separate trusted channel.
28. Provide a one-click method for reporting suspicious emails.
29. Enable phishing-resistant MFA for important accounts.
30. Use email authentication and anti-phishing filtering.
31. Repeat controlled simulations and compare results over time.
32. Provide immediate, non-punitive feedback after simulations.
33. Avoid collecting passwords or sensitive personal data during training.
34. Measure positive reporting behavior as well as click behavior.

Screenshots and Evidence

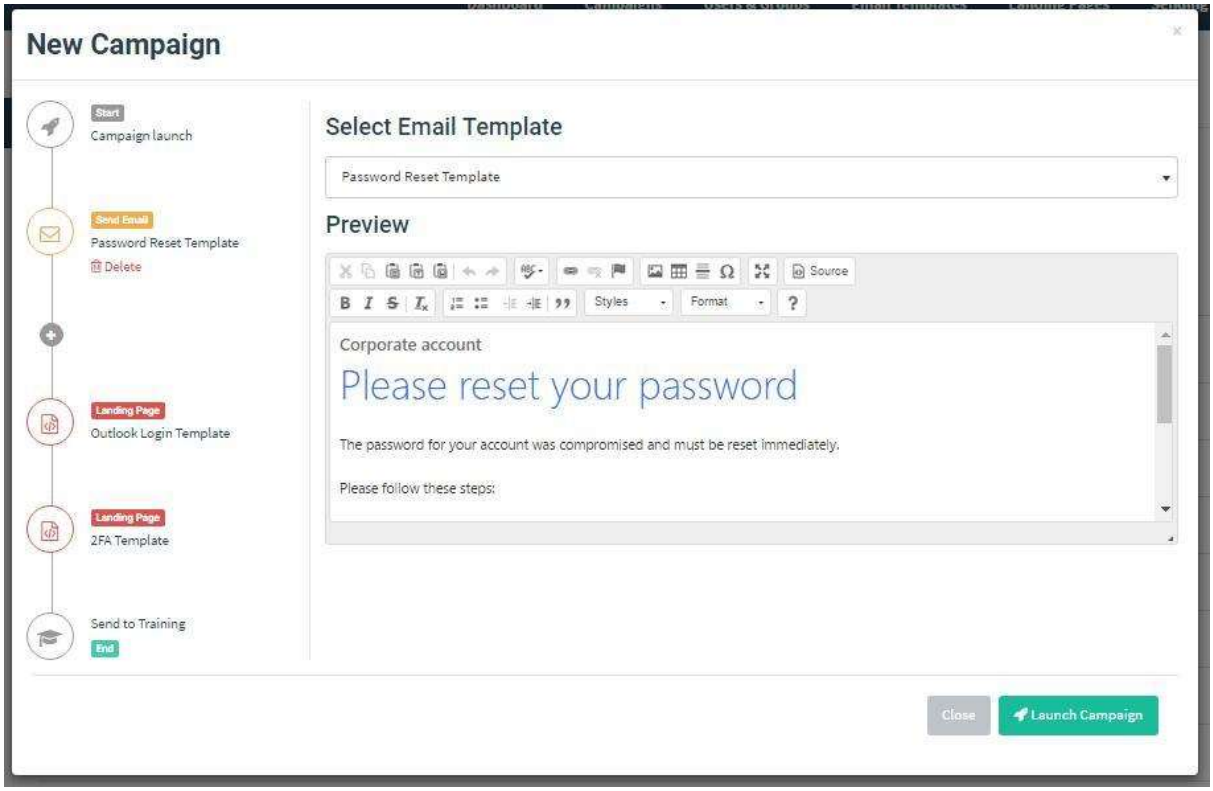
Screenshot 1: GoPhish dashboard in the lab.



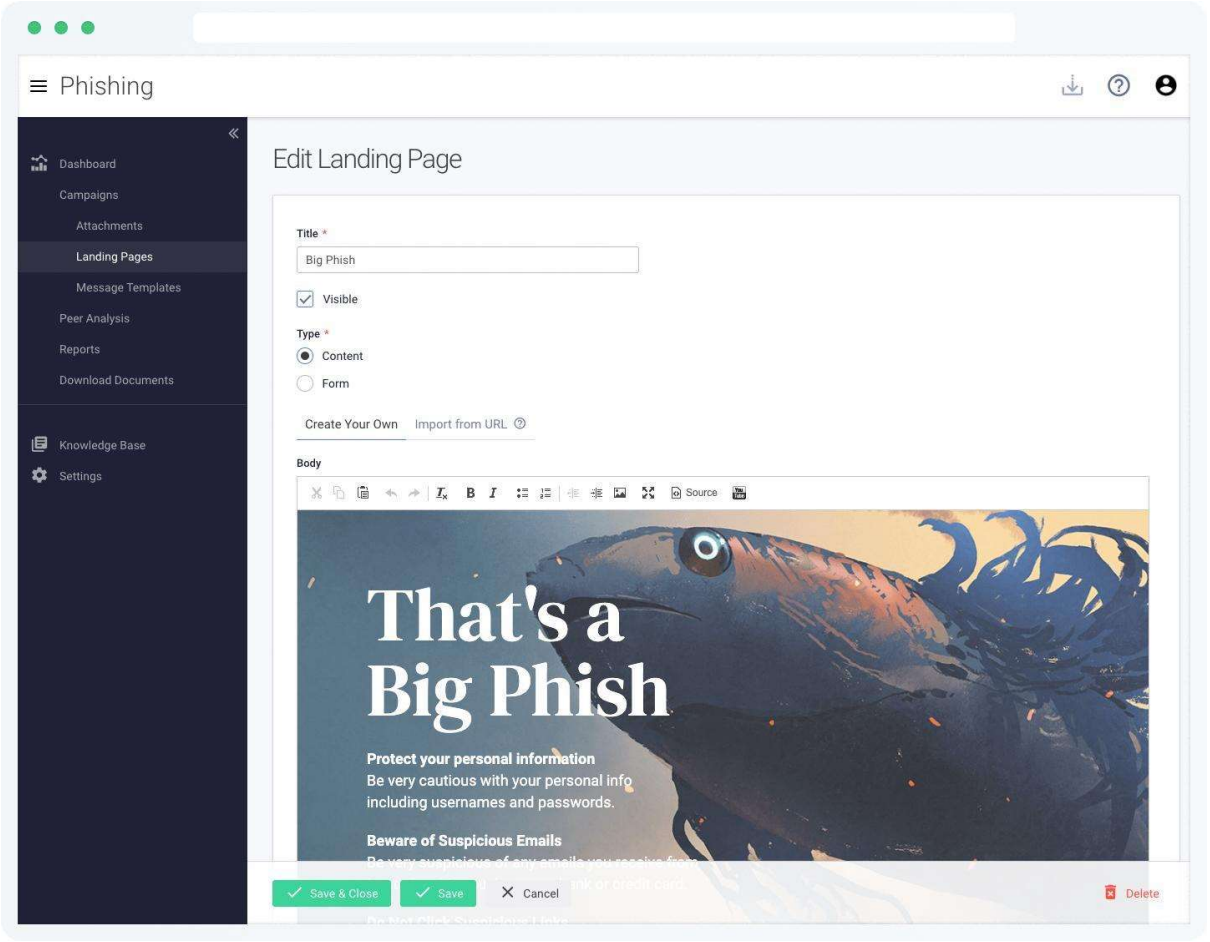
Screenshot 2: Dummy recipient group.



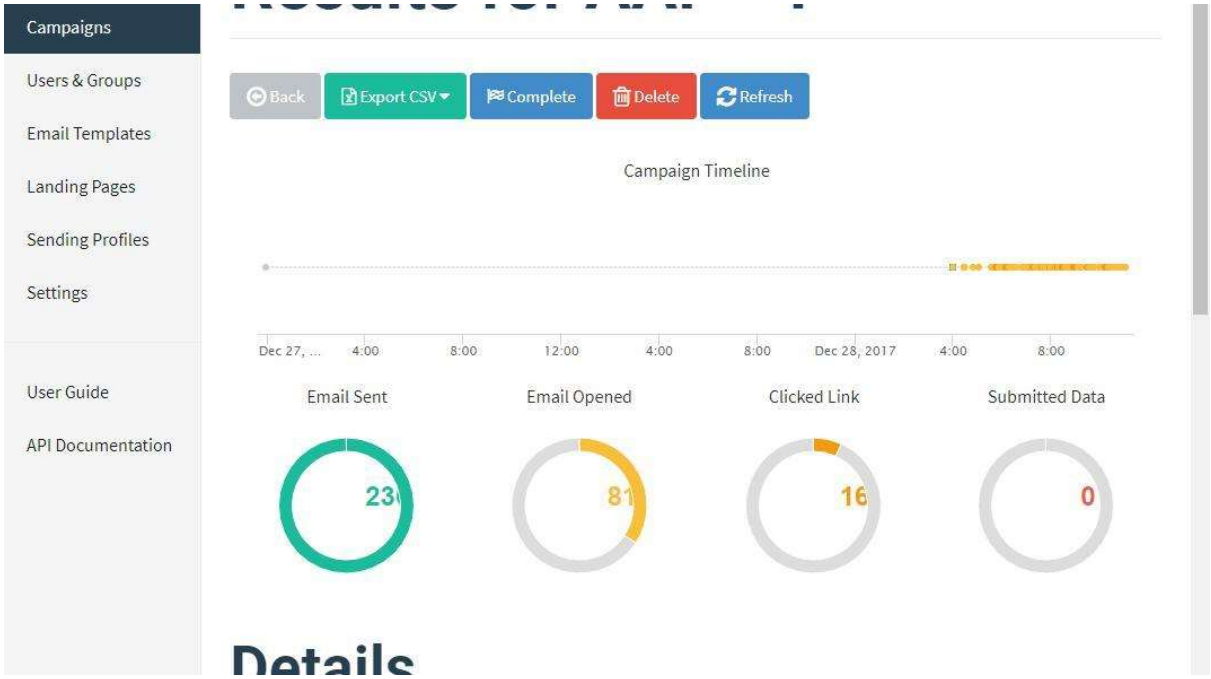
Screenshot 3: Email template preview.



Screenshot 4: Training landing page.



Screenshot 5: Campaign event summary.



Screenshot 6: Actual delivery, open, and click statistics.



Redact passwords, SMTP secrets, API keys, and real employee information from screenshots.

Result

The GoPhish procedure demonstrates how an authorized awareness campaign can measure delivery and recipient interactions. The findings can help identify training needs, improve phishing recognition, and strengthen email security.

QUESTION 3:

Nmap Aggressive Scan and Social Engineering Risk Analysis

Aim

To use Nmap's aggressive scan option against the authorized test target scanme.nmap.org, identify open ports, service versions, and operating-system information where available, and analyze how these findings could be misused in social engineering against an IT support team.

Objectives

- Perform an authorized scan of the test target.
- Identify open ports and available services.
- Collect service-version information and possible OS details.
- Explain how technical information may support social engineering.
- Recommend preventive, detective, and corrective controls.

Theory

Nmap (Network Mapper) is a network discovery and security auditing tool used to identify hosts, open ports, and network services. The -A option enables OS detection, service/version detection, default NSE script scanning, and traceroute where applicable. It may generate more traffic than a basic port scan. scanme.nmap.org is provided by the Nmap project for testing Nmap; follow the current usage policy and do not perform denial-of-service testing.

Tools Required

- Kali Linux
- Nmap
- Terminal
- Text editor for the report

Procedure and Commands

35.Check whether Nmap is installed.

```
nmap --version
```

36.Display DNS information for the target.

```
nslookup scanme.nmap.org
```

37.Run the aggressive scan within the target's permitted usage policy.

```
nmap -A scanme.nmap.org
```

38.Save the scan output to a text file.

```
nmap -A -oN nmap_report.txt scanme.nmap.org
```

39.View the saved report.

```
cat nmap_report.txt
```

Understanding Nmap Results

Output field	**Explanation**
PORT	Identifies a port and protocol.
STATE	Indicates whether a port is open, closed, or filtered.
SERVICE	Indicates the service associated with a port.
VERSION	Shows detected software/service version, if identifiable.
OS details	Provides an OS estimate when enough evidence is available.
TRACEROUTE	Shows observed network hops when supported.

An open port indicates that a service appears to accept connections; it does not automatically mean the service is vulnerable.

Findings Report Template

Fill this table from your actual Nmap output. Do not invent ports, versions, or OS details.

Finding	Actual observation	Security significance
Target hostname	scanme.nmap.org	Identifies the approved test host.
Open ports	Enter actual Nmap output	Indicates accessible network services.
Service versions	Enter actual Nmap output	Helps defenders identify outdated software.
OS detection	Enter actual Nmap output	Helps guide system inventory and hardening.
Additional script findings	Enter relevant actual output	May reveal configuration or service information.

Potential Social Engineering Misuse

Stage 1: Reconnaissance

An attacker reviews exposed services and public organizational information to build a picture of the technology environment.

Stage 2: Pretexting

An attacker may pretend to be a technician or vendor and refer to a supposed service issue to make the conversation seem credible.

Stage 3: Impersonation

An attacker may request credentials, remote access, or an urgent configuration change while pretending to be authorized IT support.

Stage 4: Defensive response

IT support should verify the requester through a trusted channel, check the ticket, follow change-control procedures, and refuse unverified requests.

This is a risk scenario, not evidence that the target or its IT team is vulnerable.

Risk Analysis

Risk	Possible impact	Preliminary priority
Misuse of exposed service information	More focused reconnaissance	Medium
Outdated software, if confirmed	Unauthorized access or disruption	High
Fake IT support request	Credential or information disclosure	High
Unauthorized remote-access approval	Potential system compromise	High

Priorities are preliminary and must be adjusted according to actual findings, exploitability, business context, and existing controls.

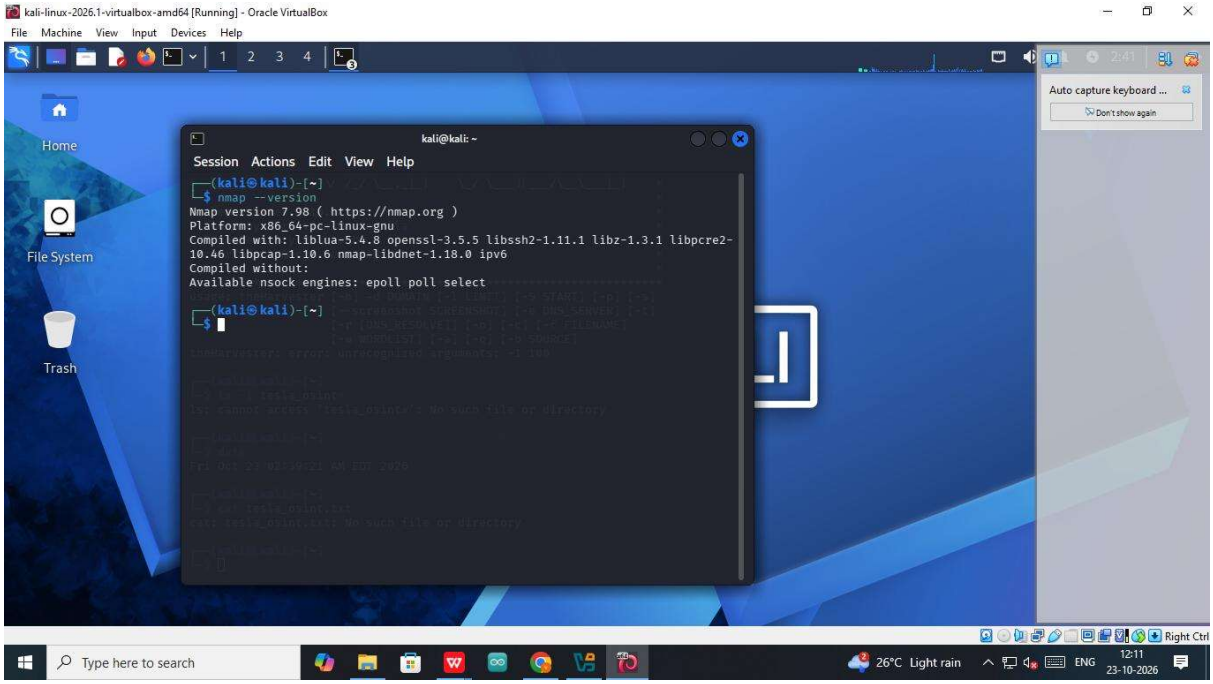
Defensive Recommendations

40. Reduce exposed services: close unnecessary ports and restrict administrative interfaces to trusted networks.
41. Patch outdated software: verify detected versions and apply supported security updates.
42. Verify IT requests: require ticket numbers and independent identity verification before sensitive changes.

43. Use MFA: protect administrator and remote-access accounts with phishing-resistant authentication where possible.
44. Monitor network activity: alert on suspicious connections, scans, and unexpected access attempts.
45. Apply least privilege: restrict user and administrator permissions to necessary tasks.
46. Maintain an asset inventory: review exposed hosts, services, and approved access paths regularly.
47. Train support staff to recognize impersonation, urgent requests, and attempts to bypass procedures.

Screenshots and Evidence

Screenshot 1: Nmap version.



Screenshot 2: DNS lookup result.



```
┌──(kali㉿kali)-[~]
└─$ dig scanme.nmap.org

; <<>> DiG 9.20.20-1-Debian <<>> scanme.nmap.org
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: FORMERR, id: 27831
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

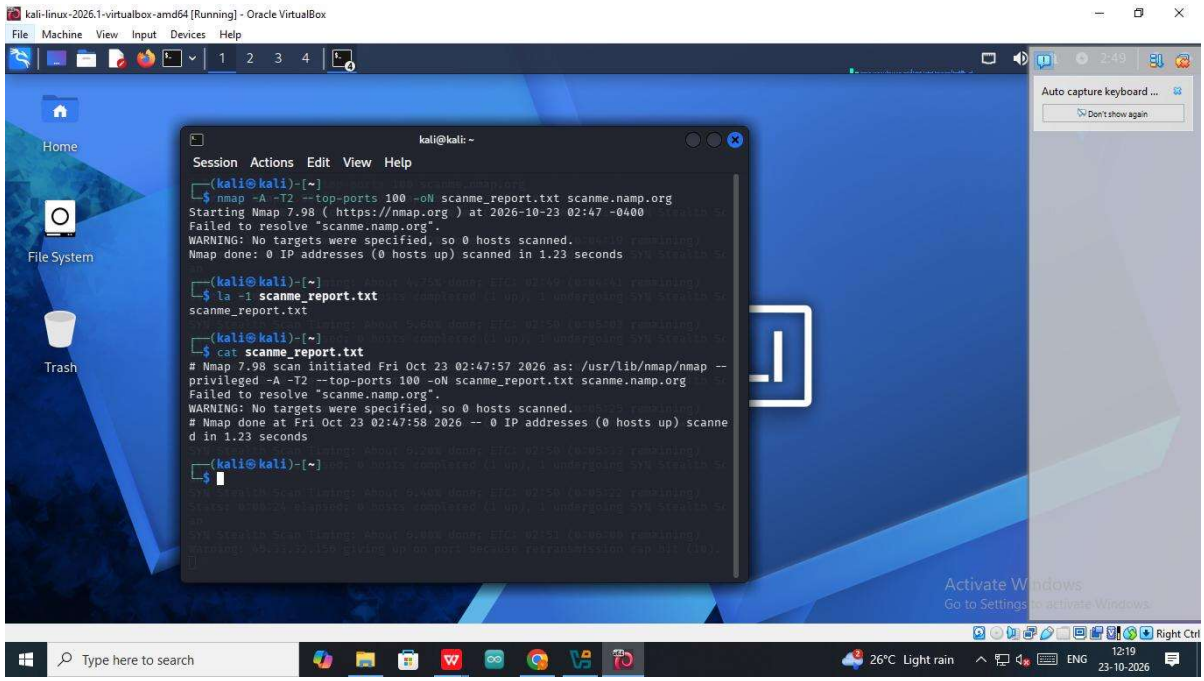
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: b5ecab1b1fd800ab (echoed)
;; QUESTION SECTION:
;scanme.nmap.org.               IN      A

;; Query time: 0 msec
;; SERVER: 172.21.100.1#53(172.21.100.1) (UDP)
;; WHEN: Fri Oct 23 02:42:58 EDT 2026
;; MSG SIZE  rcvd: 56
```

Screenshot 3: Executed nmap -A command and actual output.

```
┌──(kali㉿kali)-[~]
└─$ nmap -A  -T2 --top-ports 100 scanme.nmap.org
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-23 02:45 -0400
Stats: 0:00:08 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 3.00% done; ETC: 02:49 (0:04:19 remaining)
Stats: 0:00:15 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 4.75% done; ETC: 02:49 (0:04:41 remaining)
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 5.60% done; ETC: 02:50 (0:05:03 remaining)
Stats: 0:00:19 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 5.80% done; ETC: 02:50 (0:05:09 remaining)
Stats: 0:00:20 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 5.80% done; ETC: 02:50 (0:05:25 remaining)
Stats: 0:00:23 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 6.20% done; ETC: 02:50 (0:05:33 remaining)
Stats: 0:00:23 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 6.40% done; ETC: 02:50 (0:05:22 remaining)
Stats: 0:00:24 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 6.00% done; ETC: 02:51 (0:06:00 remaining)
```

- **Screenshot 4: Saved scan report.**



Result

The Nmap assessment demonstrates how aggressive scanning can support authorized network reconnaissance by identifying open ports, service versions, and possible OS details. The results can help defenders reduce exposure and prepare IT support staff to resist impersonation and other social engineering attacks.

FINAL REPORT: RUBRIC ALIGNMENT

Rubric criterion	Weightage	Evidence to include
Understanding of social engineering scenario	20%	Explain OSINT, phishing, pretexting, impersonation, and the purpose of the simulation.
	20%	Identify exposed information, potential phishing risks, open

Identification of attacks and vulnerabilities		services, and weaknesses supported by evidence.
Application of security concepts and countermeasures	25%	Recommend preventive, detective, and corrective controls across all questions.
Risk analysis and decision-making	20%	Explain likelihood, impact, business consequences, and reasons for prioritization.
Clarity, documentation, and technical presentation	15%	Include commands, actual screenshots, tables, calculations, limitations, and clear conclusions.

Submission Checklist

- ☐ Add your name and registration number.
- ☐ Include aim, objectives, theory, and procedure for all three questions.
- ☐ Paste the exact commands executed in the Kali Linux lab.
- ☐ Add actual screenshots and verified findings.
- ☐ Replace illustrative GoPhish statistics with campaign results.
- ☐ Include risk analysis and countermeasures for every question.
- ☐ Check grammar, formatting, and technical accuracy.
- ☐ Complete the code-of-conduct declaration and signature.